

Plantilla de Reporte Ejecutivo en PowerPoint – Encuesta OWASP 2025 – España

Esta plantilla describe la estructura recomendada de una presentación ejecutiva (PowerPoint, Keynote, etc.) para comunicar los resultados de la encuesta OWASP 2025 – España a la alta dirección, órganos de gobierno o reguladores.

Diapositiva 1 – Portada

- Título sugerido:
"Estado de la seguridad de aplicaciones y madurez OWASP – [Nombre de la organización]".
- Subtítulo:
"Resultados de la Encuesta OWASP 2025 – España".
- Elementos adicionales:
- Logo de la organización.
- Fecha.
- Nombre del responsable que presenta (CISO u otro).

Diapositiva 2 – Mensaje clave (Executive Summary)

- 3–5 mensajes clave en formato viñetas, por ejemplo:
- Nivel global de madurez (IGM) y posición relativa respecto al sector.
- Principales fortalezas (por ejemplo, buena adopción de ASVS, fuerte cultura de reporte).
- Principales debilidades (por ejemplo, baja madurez SAMM en Gobernanza, escaso uso de métricas de riesgo OWASP).
- Riesgos estratégicos derivados (alineados con NIS2/ENS).
- Próximos pasos recomendados.

El objetivo es que, si solo se ve esta diapositiva, se entienda el diagnóstico esencial.

Diapositiva 3 – Contexto y alcance

- Breve recordatorio de:
- Objetivo de la encuesta.
- Marcos utilizados (OWASP Top 10:2025, SAMM, ASVS; NIS2; ENS).
- Población cubierta (ámbito, número de aplicaciones/sistemas, unidades incluidas).
- Gráfico simple (por ejemplo, un diagrama de Venn) mostrando la intersección OWASP–NIS2–ENS.

Población cubierta (ámbito, número de aplicaciones/sistemas, unidades incluidas).

Gráfico simple (por ejemplo, un diagrama de Venn) mostrando la intersección OWASP–NIS2–ENS.

Diapositiva 4 – Índice Global de Madurez (IGM)

- Presentar el IGM global de la organización en una escala 0–100.
- Comparar con:
- Media del sector (si está disponible).
- Rango de organizaciones comparables.
- Visualización recomendada:
- Gráfico de barra horizontal o velocímetro (gauge) con bandas de color (rojo, ámbar, verde).

Rango de organizaciones comparables.

Visualización recomendada:

Diapositiva 5 – Desglose por subíndices OWASP

- Mostrar los cuatro subíndices:
- IGM-Exposición OWASP (Top 10).
- IGM-Madurez de Programa (SAMM).
- IGM-Aseguramiento Técnico (ASVS).
- IGM-Gobernanza y Cultura.
- Visualización recomendada:
- Gráfico de barras agrupadas o radar (spider chart).
- Comentario breve por subíndice (1 frase por barra).

IGM-Gobernanza y Cultura.

Visualización recomendada:

Gráfico de barras agrupadas o radar (spider chart).

Comentario breve por subíndice (1 frase por barra).

Diapositiva 6 – OWASP Top 10: exposición y remediación

- Destacar:
- Categorías OWASP más frecuentes en la organización (por ejemplo, A01, A02, A03).
- MTTR de vulnerabilidades asociadas al Top 10.
- Cobertura de análisis (porcentaje de aplicaciones evaluadas contra Top 10).
- Visualización recomendada:
- Gráfico de columnas para incidencia por categoría.
- Gráfico de barras para MTTR por criticidad.
- Mensaje clave: ¿Dónde están las principales “fugas” de seguridad en términos de vulnerabilidades conocidas?

Cobertura de análisis (porcentaje de aplicaciones evaluadas contra Top 10).

Visualización recomendada:

Gráfico de barras para MTTR por criticidad.

Mensaje clave: ¿Dónde están las principales “fugas” de seguridad en términos de vulnerabilidades conocidas?

Diapositiva 7 – Madurez OWASP SAMM

- Presentar los resultados principales de SAMM:
- Nivel medio global.
- Niveles por función (Gobernanza, Diseño, Implementación, Verificación, Operaciones).
- Situación específica de "Strategy and Metrics".
- Visualización recomendada:
- Gráfico de barras o radar.
- Comentario: cómo se compara la madurez actual con el objetivo deseado (por ejemplo, objetivo nivel 2 en X años).

Situación específica de "Strategy and Metrics".

Visualización recomendada:

Gráfico de barras o radar.

Comentario: cómo se compara la madurez actual con el objetivo deseado (por ejemplo, objetivo nivel 2 en X años).

Diapositiva 8 – Aseguramiento técnico (ASVS)

- Mostrar:
- Porcentaje de aplicaciones críticas con nivel ASVS ≥ 2 .
- Distribución de niveles ASVS por criticidad ENS/NIS2.
- Cobertura de pruebas automatizadas vs requisitos ASVS.
- Visualizaciones posibles:
- Gráfico de barras apiladas (criticidad vs nivel ASVS).
- Pie chart para cobertura de pruebas.
- Mensaje clave: ¿está la verificación a la altura de la criticidad de los servicios?

Cobertura de pruebas automatizadas vs requisitos ASVS.

Visualizaciones posibles:

Pie chart para cobertura de pruebas.

Mensaje clave: ¿está la verificación a la altura de la criticidad de los servicios?

Diapositiva 9 – Gestión del riesgo y rol de la alta dirección

- Elementos a destacar:
- Uso (o no) de la Metodología de Rating de Riesgo de OWASP y otros marcos.
- Forma de clasificar el riesgo (numérica, cualitativa, ad hoc).
- Tiempo medio desde detección técnica a decisión de riesgo.
- Visualización sugerida:
- Línea de tiempo (días) desde detección hasta decisión.
- Tabla simplificada con niveles de madurez en gobernanza.

Tiempo medio desde detección técnica a decisión de riesgo.

Visualización sugerida:

Diapositiva 10 – Cultura, formación y cadena de suministro

- Incluir:
- Porcentaje de personal técnico formado en OWASP.
- Existencia de security champions.
- Estado de la cultura de reporte de vulnerabilidades.
- Situación de la gestión de proveedores (inventario, evaluación, cláusulas OWASP/ASVS).

Visualizaciones:

- Barras para formación.
- Indicadores tipo semáforo para champions, reporte y cadena de suministro.

Situación de la gestión de proveedores (inventario, evaluación, cláusulas OWASP/ASVS).

Visualizaciones:

Diapositiva 11 – Alineamiento con NIS2 y ENS

- Tabla sintética que relacione:
- Principales hallazgos OWASP (por subíndice).
- Artículos o ámbitos clave de NIS2 afectados (gestión de riesgos, medidas técnicas, gobernanza, notificación).
- Dominios ENS relacionados.
- Mensaje: qué implicaciones regulatorias tienen los resultados, sin entrar en jerga excesivamente técnica.

Dominios ENS relacionados.

Mensaje: qué implicaciones regulatorias tienen los resultados, sin entrar en jerga excesivamente técnica.

Diapositiva 12 – Priorización de acciones

- Listar de 5 a 8 acciones prioritarias, clasificadas por horizonte temporal:
- Corto plazo (0–6 meses): “apagar fuegos con método”.
- Medio plazo (6–18 meses): consolidar procesos, reforzar ASVS y SAMM.
- Largo plazo (>18 meses): transformación cultural y gobernanza avanzada.

Cada acción con:

- Impacto esperado (alto/medio/bajo).
- Esfuerzo estimado (alto/medio/bajo).

Largo plazo (>18 meses): transformación cultural y gobernanza avanzada.

Cada acción con:

Diapositiva 13 – Indicadores de seguimiento

- Propuesta de 6–10 KPIs/KRIs derivados del IGM y de los subíndices, por ejemplo:
- % aplicaciones críticas en ASVS Nivel 2 o 3.
- MTTR de vulnerabilidades A01–A03.
- Nivel SAMM en “Strategy and Metrics”.
- % de personal técnico formado en OWASP.

% de proveedores críticos con evaluación de seguridad actualizada.

Indicar frecuencia de actualización (mensual, trimestral, anual).

% de proveedores críticos con evaluación de seguridad actualizada.

Indicar frecuencia de actualización (mensual, trimestral, anual).

Diapositiva 14 – Riesgos de no actuar

- Explicar, en 3–4 viñetas claras y sobrias, las consecuencias de mantener el statu quo, por ejemplo:
- Mayor probabilidad de incidentes graves (ransomware, brechas de datos).
- Riesgo de incumplimiento de NIS2/ENS y potenciales sanciones.
- Pérdida de confianza de clientes, ciudadanos o socios.

El objetivo es conectar métricas técnicas con el apetito de riesgo de negocio.

Diapositiva 15 – Cierre y llamada a la acción

- Resumir en una frase la idea central (por ejemplo: "Estamos en X; necesitamos llegar a Y, y el camino pasa por estas tres decisiones").
- Reforzar la necesidad de apoyo explícito de la alta dirección.
- Dejar claro el siguiente paso concreto (por ejemplo, aprobación de un programa OWASP–NIS2, constitución de comité, financiación de proyectos clave).

Esta plantilla pretende equilibrar rigor y claridad: suficiente profundidad para satisfacer a quienes leen entre líneas, y suficiente síntesis para quienes miran el reloj.